

PRD: OSINT Ingestion, Dedup & Dashboard v1

Project Inception — Threat Intelligence Platform

Phase: Now | Status: Draft v1 | Owner: Product/CPO

1. Overview

Build the foundational pipeline that ingests indicators of compromise (IOCs) from free OSINT sources, normalizes and deduplicates them into a single canonical dataset, and surfaces that data through an analyst-facing dashboard. This is the core loop the rest of the platform (scoring, ATT&CK mapping, Wazuh integration) will build on top of.

2. Problem Statement

A solo/small-team SOC analyst without budget for commercial threat intel currently has to manually check multiple free OSINT feeds, each with its own format, and mentally reconcile overlapping indicators. There's no single, deduplicated, always-current view of "what's currently known-bad," and no easy way to get that data out for use elsewhere.

3. Target Users

- **Primary (illustrative):** Solo/small-team SOC analyst evaluating free/open threat intel for their environment.
- **Secondary:** The project's own portfolio reviewer/interviewer — someone assessing whether this reflects real security-product and data-engineering judgment.

4. Goals

- Reliably ingest IOCs from multiple free OSINT sources on a recurring schedule with no manual intervention.
- Produce a single canonical, deduplicated IOC dataset from those sources.
- Give an analyst a usable web dashboard to search, filter, and inspect that data.
- Allow the analyst to get data out (CSV/JSON export) for use elsewhere.

5. Non-Goals (this phase)

- No scoring/prioritization of IOCs (Next phase)
- No MITRE ATT&CK mapping (Next phase)
- No Wazuh or any SIEM integration (Next phase)

- No multi-user auth/RBAC — single-user/local use only
- No analyst tagging/notes/case tracking (Next phase)

6. Functional Requirements

Ingestion

- **FR1:** Ingest indicators from at least 3 free OSINT sources at launch: AlienVault OTX, abuse.ch (URLhaus + ThreatFox), CISA KEV.
- **FR2:** Run ingestion on a recurring schedule per source, unattended.
- **FR3:** Log every ingestion run (source, timestamp, record count, success/failure) to support the ingestion health widget.
- **FR4:** Handle a source being unavailable or rate-limited without crashing the pipeline or losing previously ingested data (retry/backoff).

Normalization

- **FR5:** Transform raw records from each source into a canonical IOC schema: indicator type (IP, domain, URL, file hash, CVE), value, contributing source(s), first seen, last seen, raw source metadata retained for traceability.
- **FR6:** Reject/flag malformed records (invalid IP/domain/hash format) rather than storing them as valid data.

Deduplication

- **FR7:** Detect and merge the same indicator seen across multiple sources or multiple runs into one canonical record, preserving all contributing sources and updating "last seen."
- **FR8:** Dedup logic must be deterministic and auditable — an analyst can see why two records were merged.

Storage

- **FR9:** Canonical IOCs persisted in a durable store (Postgres) as system of record.

Dashboard v1

- **FR10:** Searchable, filterable IOC table (filter by type, source, date range).
- **FR11:** Per-source volume chart (indicators ingested per source over time).
- **FR12:** Ingestion health widget (last run time/status per source).
- **FR13:** IOC detail view showing contributing sources and raw metadata.

Export

- **FR14:** Export the current filtered IOC set as CSV and JSON.

7. Non-Functional Requirements

- **Reliability:** a failure in one source's ingestion must not block others.
- **Data integrity:** failed runs must be visibly flagged, never silently dropped.
- **Performance:** dashboard stays responsive at demo-realistic scale (~100k indicators) — not engineered for enterprise throughput.
- **Safety:** since this stores live malware/malicious-infra indicators, URLs and hashes must be displayed defanged (e.g., hxxp://) to avoid accidental clicks/execution.
- **Portability:** must run self-hosted/locally with no required cloud dependency.

8. Success Metrics (portfolio-framed)

- ≥95% successful scheduled-run rate across all 3 sources over a 2-week window.
- A concrete, quotable dedup number: "X raw records → Y canonical IOCs (Z% dedup rate)."
- Can be demoed live end-to-end with real current threat data: ingest → dedup → search/filter → export.
- Clean separation between ingestion / normalization / dedup / storage layers, defensible in a technical interview.

9. Scope & Phasing

This PRD covers the **Now** phase only. Scoring, ATT&CK mapping, and Wazuh integration (dashboard v2) are **Next**; the Wazuh alert feedback loop, correlation, and RBAC are **Later** — each will get its own PRD once this phase ships.

10. Open Questions for the CTO / TRD

- Source-specific API auth and rate limits (OTX, abuse.ch, CISA KEV).
- Scheduling mechanism (cron vs. APScheduler vs. other).
- Canonical schema field design and STIX-alignment depth.
- Exact dedup algorithm (strict match vs. fuzzy matching, and on which fields).
- Frontend stack for the dashboard.
- Deployment model (Docker Compose vs. local runtime).